

Methodology Bug Bounty

Apa itu Bug Bounty

Bug bounty adalah sebuah program yang dibuat oleh para perusahaan atau developer untuk memberikan apresiasi berupa uang kepada para hacker. Apresiasi tersebut diberikan kepada para hacker yang berhasil menemukan dan melaporkan bug pada website atau aplikasi mereka. Program ini saling menguntungkan antara hacker dengan perusahaan. Di mana, perusahaan mendapatkan benefit berupa laporan bug, sehingga bisa meningkatkan sistem keamanan mereka. Sedangkan, hacker mendapatkan benefit berupa hadiah uang maupun barang. Biasanya, program bug bounty ini dilakukan oleh hacker yang disebut bug hunter. Bug hunter akan "menyerang" dan menganalisa jika sebuah serangan yang mereka buat bisa berdampak buruk pada segi keamanan.

Bug hunter akan menemukan bug di sebuah program. Setelah bug ditemukan, para bug hunter akan menulis laporan yang mana nanti laporan tersebut akan dikirim dan ditindaklanjuti oleh pihak developer dengan rincian sebagai berikut:

1. Jenis bug
2. Bagaimana pengaruh bug tersebut terhadap program
3. Tingkat keparahan bug
4. Setelah mengisi laporan, bug hunter perlu menyertakan langkah-langkah dan detail utama bug tersebut untuk membantu pihak developer mereplikasi dan memvalidasi bug tersebut.
5. Setelah developer perusahaan meninjau dan mengkonfirmasi bug tersebut, barulah perusahaan memberi hadiah kepada bug hunter sebagai bentuk apresiasi.

Platform Bug Bounty

- **HackerOne** (<https://hackerone.com>)
Platform bug bounty paling populer yang digunakan oleh banyak perusahaan besar seperti Uber, Twitter, dan GitHub. Menyediakan dashboard yang lengkap dan komunitas aktif.
 - **Bugcrowd** (<https://www.bugcrowd.com>)
Menyediakan platform crowd-sourced security dengan model private dan public program. Bugcrowd memiliki sistem reputasi dan penilaian untuk para bug hunter.
 - **Intigriti** (<https://www.intigriti.com>)
Berbasis di Eropa, menawarkan program bug bounty dan pentest dengan model real-time dan gamifikasi. Cocok untuk perusahaan yang ingin compliance terhadap GDPR.
-

Methodology Bug Bounty

1. Reconnaissance (Subdomain Enumeration & Initial Scanning)

Langkah awal dalam proses bug bounty untuk memahami permukaan serangan.

- **Subdomain Enumeration**

Cari subdomain aktif dari target menggunakan tools seperti:

- `assetfinder`, `amass`, `subfinder`
- `crt.sh`, `dnsdumpster`, `certspotter`

- **Port & Service Scanning**

Identifikasi port terbuka dan layanan menggunakan:

- `nmap`, `rustscan`, `naabu`

- **Directory & File Brute-Forcing**

Temukan path tersembunyi:

- `ffuf`, `dirsearch`, `gobuster`

2. Target Analysis

Pahami cara kerja aplikasi/web sebelum mencari celah.

- **Review struktur aplikasi:** Endpoint, parameter, fitur login/logout, API.
- **Amati interaksi user:** Mekanisme login, session handling, authorization.
- **Periksa teknologi yang digunakan:** WAF, CMS, framework JS, dll.

3. Vulnerability Discovery

Cari celah keamanan berdasarkan pemahaman di tahap sebelumnya.

- **Authentication Issues:**
 - Brute-force, default credentials, bypass login.
- **Authorization Issues:**
 - IDOR (Insecure Direct Object Reference), broken access control.
- **Input-Based Bugs:**
 - XSS, SQL Injection, Command Injection, SSRF, SSTI.
- **Business Logic Bugs:**
 - Salah hitung diskon, bypass limit transaksi, manipulasi flow aplikasi.
- **Client-Side Issues:**
 - DOM XSS, CORS misconfiguration, Clickjacking.
- **API Issues:**

- Rate limiting bypass, mass assignment, improper input validation.

4. Exploitation

Buktikan bahwa celah tersebut benar-benar bisa dieksploitasi:

- **PoC (Proof of Concept)**
Buat bukti yang dapat dipahami tim keamanan.
- **Impact Analysis**
Jelaskan potensi dampak bagi user, data, atau sistem.
- **Hindari DoS/kerusakan permanen** saat eksploitasi.

5. Reporting

Laporkan temuan dengan jelas dan profesional.

- **Jelaskan langkah demi langkah**
- **Berikan PoC** (screenshot, video, request/response)
- **Sertakan rekomendasi perbaikan**
- Gunakan bahasa sopan, non-menyerang

6. Retesting (Jika diizinkan)

Setelah tim memperbaiki bug, kamu bisa:

- Verifikasi patching
- Lakukan regression testing untuk pastikan tidak muncul bug lain

referensi

- [Bug-Bounty-Hunting-Methodology-2025](#)
- [chatgpt](#)